# Definitions - B

**PURPOSE:** This document provides a list of words and definitions to clarify Information Specific (IT) terminology contained within State of Wyoming Policies and Standards.

## I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, and temporary employees.

## II. DEFINITIONS

- Backdoor: Typically unauthorized hidden software or hardware mechanism used to circumvent security controls. (SOURCE: CNSSI-4009); An undocumented way of gaining access to a computer system. A backdoor is a potential security risk. (SOURCE: NIST SP 800-82)

- Bandwidth: Commonly used to mean the capacity of a communication channel to pass data through the channel in a given amount of time. Usually expressed in bits per second. (SOURCE: Safety Engineering: Principles and Practices)

- Banner: The information that is displayed to a remote user trying to connect to a service. This may include version information, system information, or a warning about authorized use. (SOURCE: Intrusion Detection Systems)

- Banner Grabbing: The process of capturing banner information—such as application type and version—that is transmitted by a remote port when a connection is initiated. (SOURCE: NIST SP 800-115)

- Baseline: Hardware, software, databases, and relevant documentation for an information system at a given point in time. (SOURCE: CNSSI-4009)

- Baseline Assessment: An interim compliance validation assessment performed by a QSA to determine the PCI Security compliance status. (SOURCE: VERIZON PCI SECURITY)

- Baseline Configuration: A set of specifications for a system, or Configuration Item (CI) within a system, that has been formally reviewed and agreed on at a given point in time and which can be changed only through change control procedures. The baseline configuration is used as a basis for future builds, releases, and/or changes. (SOURCE: NIST SP 800-128)

- Baseline Security: The minimum security controls required for safeguarding an IT system based on its identified needs for confidentiality, integrity, and/or availability protection. (SOURCE: NIST SP 800-16)

- Baselining: Monitoring resources to determine typical utilization patterns so that significant deviations can be detected. (SOURCE: NIST SP 800-61)

- Basic Testing: A test methodology that assumes no knowledge of the internal structure and implementation detail of the assessment object. Also known as black box testing. (SOURCE: NIST SP 800-53A)

- Best Practice: A proven activity or process that has been successfully used by multiple enterprises. (SOURCE: ISACA)

- Biometric: A physical or behavioral characteristic of a human being. (SOURCE: NIST SP 800-32) A measurable physical characteristic or personal behavioral trait used to recognize the identity or verify the claimed identity of an applicant. Facial images, fingerprints, and iris scan samples are all examples of biometrics. (SOURCE: FIPS 201)

- Biometric Information: The stored electronic information pertaining to a biometric. This information can be in terms of raw or compressed pixels or in terms of some characteristic (e.g., patterns.) (SOURCE: FIPS 201)

- Biometric System: An automated system capable of: 1) capturing a biometric sample from an end user; 2) extracting biometric data from that sample; 3) comparing the extracted biometric data with data contained in one or more references; 4) deciding how well they match; and 5) indicating whether or not an identification or verification of identity has been achieved. (SOURCE: FIPS 201)
- Blacklist: A list of email senders who have previously sent spam to a user. (SOURCE: NIST SP 800-114) A list of discrete affiliates, such as hosts or

applications that have been previously determined to be associated with malicious activity. (SOURCE: NIST SP 800-94)

- Blacklisting: The process of the system invalidating a user ID based on the user's inappropriate actions. A blacklisted user ID cannot be used to log on to the system, even with the correct authenticator. Blacklisting and lifting of a blacklisting are both security-relevant events. Blacklisting also applies to blocks placed against IP addresses to prevent inappropriate or unauthorized use of Internet resources. (SOURCE: CNSSI-4009)

- Blog: A discussion or informational site published on the World Wide Web that consists of discrete entries ("posts") typically displayed in reverse chronological order (the most recent post appears first). Blogs may be the work of a single individual, occasionally of a small group, and covering a single subject, or may include posts written by large numbers of authors and professionally edited. (SOURCE: WIKIPEDIA)

- Boundary Protection: Monitoring and control of communications at the external boundary of an information system to prevent and detect malicious and other unauthorized communication through the use of boundary protection devices (e.g., proxies, gateways, routers, firewalls, guards, encrypted tunnels). (SOURCE: NIST SP 800-53; CNSSI-4009)

- Boundary Protection Device: A device with appropriate mechanisms that: 1. facilitates the adjudication of different interconnected system security policies (e.g., controlling the flow of information into or out of an interconnected system); and/or 2. provides information system boundary protection. (SOURCE: NIST SP 800-53)

  A device with appropriate mechanisms that facilitate the adjudication of different security policies for interconnected systems. (SOURCE: CNSSI-4009)

- Breach: The loss of control, compromise, unauthorized disclosure, unauthorized acquisition, or any similar occurrence where a person other than an authorized user accesses or potentially accesses personally identifiable information or an authorized user accesses personally identifiable information for an other than authorized purpose. (SOURCE: US OMB M-17-12) An impermissible use or disclosure under the Privacy Rule that compromises the security or privacy of the protected health information. An impermissible use or disclosure of protected health information is presumed to be a breach unless the covered affiliate or

business associate, as applicable, demonstrates that there is a low probability that the protected health information has been compromised based on a risk assessment of at least the following factors: 1. The nature and extent of the protected health information involved, including the types of identifiers and the likelihood of re-identification; 2. The unauthorized person who used the protected health information or to whom the disclosure was made; 3. Whether the protected health information was actually acquired or viewed; and 4. The extent to which the risk to the protected health information has been mitigated. (SOURCE: HIPAA (45 CFR §§ 164.400-414)

- Breach of Security: "Breach of security" means unauthorized access to electronic files, media, or data containing personal information that compromises the security, confidentiality, or integrity of personal information when access to the personal information has not been secured by encryption or by any other method or technology that renders the personal information unreadable or unusable. Good faith acquisition of personal information by an employee or agent of the business for a legitimate business purpose is not a breach of security, provided that the personal information is not used for a purpose unrelated to the business or subject to further unauthorized disclosure. (SOURCE: N.J.S.A 2C.56:8-161)

- Brute Force Password Attack: A method of accessing an obstructed device by attempting multiple combinations of numeric and/or alphanumeric passwords. (SOURCE: NIST SP 800-72)

- Buffer Overflow: A condition at an interface under which more input can be placed into a buffer or data holding area than the capacity allocated, overwriting other information. Attackers exploit such a condition to crash a system or to insert specially crafted code that allows them to gain control of the system. (SOURCE: NIST SP 800-28; CNSSI-4009)

- Business Associate: A person or affiliate that performs certain functions or activities that involve the use or disclosure of protected health information on behalf of, or provides services to, a covered affiliate. (SOURCE: US Department of Health and Human Services)

- Business Continuity Plan (BCP): The documentation of a predetermined set of instructions or procedures that describe how an organization's mission/business processes will be sustained during and after a significant disruption. (SOURCE: NIST SP 800-34; CNSSI-4009)

- Business Affiliate: All trusted Affiliates that are authorized and/or contracted with a Department and/or Agency within the Executive Branch of State Government for the purpose of this policy. Business Affiliate may include other governmental agencies outside the Executive Branch

- Business Impact Analysis (BIA): An analysis of an information system's requirements, functions, and interdependencies used to characterize system contingency requirements and priorities in the event of a significant disruption. (SOURCE: NIST SP 800-34); An analysis of an enterprise's requirements, processes, and interdependencies used to characterize information system contingency requirements and priorities in the event of a significant disruption. (SOURCE: CNSSI-4009)

# DOCUMENT HISTORY

| ORIGINAL SUBMISSION | | | | |
|---|---|---|---|---|
| SUBMITTED ON | SUBMITTED BY | APPROVED BY | ISSUED DATE | EFFECTIVE DATE |
| | | | | |
| | | | | |
| | | | | |

| REVISIONS | | |
|---|---|---|
| LAST REVISION DATE | LAST REVISED BY | LAST APPROVED BY |
| | | |
| | | |
| | | |

| REVIEWS | | |
|---|---|---|
| LAST REVIEW DATE | LAST REVIEWED BY | NEXT REVIEW DATE |
| | | |
| | | |
| | | |